EXECUTIVE SUMMARY · CAPSTONE 2

AI-Powered Phishing Awareness & Risk-Scoring Platform

Sanad Al-Khatib · Omar Al Sheikh Khalil · Ghassan Hittini · Saad Thibian · Al-Hussein Technical University

A phishing-awareness programme that measures what actually happened during a simulated attack — not just whether someone clicked — turns that into a per-person risk score, and automatically assigns training to the people who need it.

WHAT IT IS	WHO IT'S FOR	WHY IT'S RESPONSIBLE	STATUS
A complete platform that runs an organisation's phishing-awareness programme end to end, from one console.	Security and GRC teams who need to know which employees carry the most risk and whether training is working.	It only measures behaviour and trains people. It never writes or sends a phishing email itself, and no credential ever enters the system.	A complete, tested working platform, hardened across two security reviews and demonstrated end to end across both services.

The problem with a click rate

Most phishing-awareness programmes report one number: the percentage of people who clicked. That number throws away everything that matters. It doesn't say who is most at risk, how far a person went (clicking a link is a very different signal from typing a password), how convincing the lure was, or whether behaviour is improving. And even once a team knows who is at risk, turning that into the right training for the right person — with a record that it happened — is a separate manual chore. Without those answers, a security team cannot focus its attention or prove the programme is working.

What the platform does

The platform runs the whole programme around one firm principle: it measures and trains, but never manufactures the attack.

- **Measure.** Turns the results of an authorised simulation into a Human Risk Score (0–100) for every employee, banded Low/Moderate/High/Critical, with a department heatmap and a trend over time.
- **Identify.** Builds the employee roster directly from the organisation's own directory — Microsoft Entra ID or an on-premise Active Directory — reading names and job details, never a password.
- **Orchestrate.** Launches, schedules and manages the simulated tests from the same console, behind an explicit "this is authorised" confirmation and a full audit trail.

- **Remediate.** When someone fails a test or stays at high risk, a companion Awareness & Remediation Portal automatically assigns training and, if the risk persists, raises a ticket for a human to follow up.

> The score is deliberately explainable: someone who merely opened an email scores far lower than someone who typed a password, being fooled by a convincing targeted fake counts for more than falling for an obvious one, and older mistakes gradually count for less as behaviour improves — so a team that is getting better can see the trend move. Every number a person is measured by can be traced back to a specific event and a published weighting.

Closing the loop: training and follow-up

Measuring risk is only half the job. A separate Awareness & Remediation Portal turns a score into a response automatically. New staff are assigned a short, non-skippable lesson and a passed exam before they count as trained. Someone who later fails a practice test, or is caught by a newly published policy, is assigned targeted refresher training on an escalating ladder. And if a person stays at high risk for too long, the portal flags them for in-person follow-up and raises a ticket in the organisation's own help-desk system — so nothing falls through the cracks. The seeded training content links to free, reputable sources (CISA, the UK's NCSC, SANS) that an organisation can extend with its own material.

How it works, in plain terms

The organisation runs its simulated tests with a standard, separate tool (GoPhish) that it already controls, and can now drive entirely from this platform's console. As employees interact with a test, the platform receives a record of what happened — opened, clicked, entered details — and turns it into risk scores and dashboards. A security manager sees everything from one screen: which people and departments need attention, whether the numbers are trending the right way, and who is currently in training or awaiting follow-up.

Built responsibly

The design draws a firm line that makes the platform safe to operate:

- **It measures and trains, it does not attack.** The fake emails and fake login pages are always authored inside the separate, authorised testing tool. The platform selects and uses them; it never composes or clones them.
- **It does not generate the phishing messages — deliberately.** The original project proposal included an AI component that would write the simulated phishing emails itself. That component was not built, by decision rather than by omission: software that generates personalised phishing text from real staff data is an offensive capability regardless of the intent behind it, and the platform's scientific contribution — the risk-scoring model — does not depend on who wrote the lure. The technical report sets out the full reasoning.
- **It never stores a password.** Even when an employee types one into a test page, the platform records only the fact that it happened. This is enforced three separate ways in the code, not by policy alone — there is no column in the database that could hold one.
- **Every integration secret is encrypted at rest.** API keys, webhook secrets and directory credentials are encrypted in the database, not just hidden from the interface, so a copy of the database alone reveals nothing.
- **Sessions are hardened against the two common web attacks.** The console holds a session in a cookie a script cannot read (defeating session theft through a cross-site scripting flaw), paired with a second check that stops a forged cross-site request.
- **Access is controlled, scoped and logged.** Staff see only what their role allows, a department manager sees only their department, and the two services that talk to each other use a narrowly-

scoped, rotatable token — never a shared admin login.

What it delivers

- **Focus.** Know exactly which employees and departments carry the most risk, so training and attention go where they matter.
- **Proof.** Show leadership whether awareness is genuinely improving over time, with defensible, explainable numbers.
- **Prioritisation.** A separate view weights senior roles higher for triage, without penalising an individual for their job title.
- **Action, automatically.** A high score doesn't just sit on a dashboard — it triggers the right training and, if needed, a follow-up ticket.
- **One place to work.** Set up the roster, run the programme, read the results and manage remediation from a single console.

119	4	0	2
AUTOMATED TESTS	SERVICES, ONE CONSOLE	CREDENTIALS STORED	DIRECTORY CONNECTORS

Current status and next steps

The platform is a complete, tested working version (MVP), covered by 119 automated tests, and it has been demonstrated end to end across both services: a real simulated-phishing run flowed through the system and produced a correct, explainable risk score with no password ever stored; a new employee was onboarded, assigned training, and — after being pushed to high risk — automatically moved into remediation with a follow-up ticket raised.

It has also been through two rounds of security review plus an independent audit of the whole codebase, covering session handling, secret storage, tenant isolation, service-to-service permissions and the common web-application attack classes, with clean automated dependency scans. Each round found a different class of issue, which is itself part of the result: security work on a system of this size is iterative, and the report documents what each pass found and why.

To move from a working demonstration to day-to-day operational use, the remaining steps are largely organisational rather than technical: run one fully authorised test campaign with real staff (with the appropriate sign-off), gather feedback to fine-tune the scoring, and deploy it on the organisation's own infrastructure.